COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.2 · AAA (Authentication, Authorization, Accounting)

Mestre CyberSec · **Lesson 1.2 — AAA (Authentication, Authorization, Accounting)** (9:03) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** AAA: Authentication (prova quem é), Authorization (o que pode fazer), Accounting (registra o que fez). 802.1X usa RADIUS pra AAA de rede — quem conecta o cabo precisa se autenticar antes de ter acesso.

💡 Key Exam Highlights & Critical Concepts

- 'Prove quem és, define o que podes, registra o que fez'
- 802.1X: acesso físico à rede precisa de login — sem isso, qualquer dispositivo entra
- RADIUS = o backend central de AAA

🎯 Exam Tips & Typical CompTIA Scenarios

- A prova menciona: 'network access control requires users to authenticate' = 802.1X + RADIUS
- Accounting = LOG de acesso (quem entrou quando) — não é accounting financeiro

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.2 — AAA (Authentication, Authorization, Accounting))

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• AAA (Authentication, Authorization, Accounting)

Security framework combining Authentication (proving identity), Authorization (defining what an identity can do), and Accounting (logging what was done). It is the standard model for controlling and auditing access to networks and systems on the SY0-701 exam.

⚠️ ***Exam Trap:*** *'Prove quem és, define o que podes, registra o que fez.' Se a pergunta disser 'track/record what the user did', a resposta é Accounting — cuidado com a pegadinha de achar que se trata de contabilidade financeira.*

• Authentication (AuthN)

The process of verifying a user's identity using credentials such as passwords, smart cards, or biometrics before any access is granted.

⚠️ ***Exam Trap:*** *Gatilho: 'verify identity' / 'prove who you are' = Authentication. Distinção chave: autenticação responde 'quem é você'; autorização responde 'o que você pode fazer' — a prova adora trocar as duas.*

• Authorization (AuthZ)

Defines the rights and permissions granted to an already authenticated user — which resources they may access and which actions they may perform.

⚠️ ***Exam Trap:*** *Ordem importa: primeiro Authentication, depois Authorization. Gatilho: 'what are you allowed to access/do' = Authorization; 'who are you' = Authentication.*

• Accounting (Acct)

The AAA function that logs user activity and access events — who connected, when, and what resources were used — creating an audit trail.

⚠️ ***Exam Trap:*** *Na prova, Accounting = LOG de acesso (quem entrou e quando). Gatilho: 'track user access' ou 'maintain logs of usage' → Accounting. NÃO é accounting financeiro — pegadinha clássica do termo.*

• IEEE 802.1X

IEEE standard for port-based Network Access Control that blocks all traffic on a switch port or wireless link until the client authenticates; the switch/access point forwards credentials to an authentication server (RADIUS).

⚠️ ***Exam Trap:*** *Trigger da prova: 'network access control requires users to authenticate before connecting' ou 'port-based authentication' = 802.1X. Sem 802.1X, qualquer dispositivo que conecta o cabo entra na rede. Papéis: Supplicant (cliente), Authenticator (switch/AP), Authentication Server (RADIUS).*

• RADIUS (Remote Authentication Dial-In User Service)

Centralised AAA protocol providing authentication, authorization, and accounting services for network access; the most common backend server paired with 802.1X. Uses UDP ports 1812/1813 and encrypts only the password field.

⚠️ ***Exam Trap:*** *Dupla clássica da prova: 802.1X (na porta do switch) + RADIUS (backend central de AAA). Distinção para não errar: RADIUS = UDP, cripta só a senha, foco em acesso à rede; TACACS+ = TCP 49, cripta tudo, foco em administração de dispositivos.*

• TACACS+ (Terminal Access Controller Access-Control System Plus)

Cisco-developed AAA protocol that fully encrypts the entire packet, separates each AAA function, and is typically used for administering network devices; runs over TCP port 49.

⚠️ ***Exam Trap:*** *Comparação obrigatória da prova: RADIUS (UDP 1812/1813, cripta só a senha, acesso à rede/802.1X) vs TACACS+ (TCP 49, cripta tudo, device administration). Trocar esses dois na questão = erro clássico.*

• NAC (Network Access Control)

Security approach that determines whether a device may join the network, typically requiring authentication (and sometimes device health checks) before granting access; 802.1X is its port-based authentication implementation.

⚠️ ***Exam Trap:*** *Quando a prova escrever 'network access control requires users to authenticate', a resposta é 802.1X + RADIUS. Distinção: NAC é o conceito amplo (pode incluir posture checks); 802.1X é o mecanismo de autenticação por porta que a citação descreve.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 The Three AAA Pillars: Who You Are, What You Can Do, and What You Did

🏠 **Real-World Analogy:** A high-security corporate skyscraper lobby. First, you present your government-issued passport to the security desk to verify your identity (Authentication). Next, the guard checks the visitor manifest and codes your badge to open only the 4th-floor finance conference room, denying access to all other floors (Authorization). Finally, the turnstile access database logs your exact arrival time, every door badge scan, and your departure timestamp (Accounting).

🔍 **Root Cause & Background:** Without formal AAA separation, legacy networks granted blanket administrative access immediately upon simple password verification (conflating authentication with authorization) or failed to maintain detailed audit logs, preventing forensic attribution during insider data thefts.

🛡️ **GRC Auditor Perspective:** Auditors independently inspect each AAA component: 1) MFA enforcement and SSO directory sync (Authentication); 2) Principle of Least Privilege and Segregation of Duties matrices (Authorization); 3) Centralized SIEM audit log ingestion and mandatory 1-year retention policies (Accounting).

⚠️ **How CompTIA Tests This:** Vital CompTIA exam distinction: Authentication = proving WHO you are (passwords, smartcards, biometrics). Authorization = determining WHAT you are permitted to access (permissions, ACLs, RBAC). Accounting = recording WHAT you did and duration (audit logs, logon timestamps, bandwidth chargeback).

📌 Port-Based Network Access Control: IEEE 802.1X

🏠 **Real-World Analogy:** A smart wall electrical outlet in an enterprise facility that stays completely de-energized until an authorized employee badge taps the sensor. If an unauthorized visitor plugs an Ethernet cable into a conference room wall jack, the switch port remains locked down, dropping all frames until valid corporate credentials authenticate against the central server.

🔍 **Root Cause & Background:** Anyone physically walking into an office (visitors, contractors, rogue janitorial staff) could easily plug an unmanaged laptop directly into an open wall Ethernet port, obtaining unrestricted access to core internal subnets without passing through a single perimeter firewall.

🛡️ **GRC Auditor Perspective:** Network security auditors verify IEEE 802.1X Network Access Control (NAC) enforcement across all physical switch ports and corporate Wi-Fi SSIDs, ensuring rogue or unmanaged machines are blocked or isolated into a quarantined guest VLAN.

⚠️ **How CompTIA Tests This:** Exam scenario cues: 'Port-based Network Access Control (PNAC)', 'Enterprise Wi-Fi or physical switch requiring authentication before granting IP connectivity', 'Supplicant, Authenticator, Authentication Server'. Target answer: IEEE 802.1X.

📌 AAA Core Protocols: RADIUS vs. TACACS+

🏠 **Real-World Analogy:** RADIUS is like a city subway smartcard: tapping it at the turnstile validates your identity and authorizes platform entry in a single combined transaction (Authentication and Authorization merged) over fast UDP. TACACS+ is like a NASA mission control console: every single command typed by an engineer ('reboot interface', 'modify routing') is inspected individually over a fully encrypted TCP tunnel, enabling granular command-by-command authorization.

🔍 **Root Cause & Background:** Managing local administrator user accounts on hundreds of individual switches, firewalls, and VPN gateways caused administrative chaos: shared passwords, orphaned accounts, and catastrophic inability to immediately revoke access when a network engineer resigned.

🛡️ **GRC Auditor Perspective:** Auditors mandate: 1) TACACS+ for network device administration (enabling granular CLI command authorization and logging of every admin keystroke); 2) RADIUS for remote access VPNs, 802.1X network edge access, and enterprise Wi-Fi authentication.

⚠️ **How CompTIA Tests This:** The definitive CompTIA exam comparison: RADIUS = UDP (ports 1812/1813), combines Authentication & Authorization, encrypts only the password. TACACS+ = TCP (port 49), separates Authentication, Authorization, and Accounting, and encrypts the entire payload. Device administration (CLI control) = TACACS+. End-user Wi-Fi/802.1X/VPN access = RADIUS.

📌 Accounting: The Unflinching Record of User Behavior

🏠 **Real-World Analogy:** A commercial truck's certified tachograph or an itemized credit card billing statement. The tachograph doesn't decide who turns the ignition or select which highways are legal; it indelibly logs exact speed, stopovers, driving duration, and emergency braking events across the entire journey.

🔍 **Root Cause & Background:** During a security incident or insider investigation, incident responders must reconstruct with forensic certainty who logged on, which commands were executed, what data volume was moved, and exact session timestamps.

🛡️ **GRC Auditor Perspective:** In accordance with PCI-DSS (Requirement 10) and ISO 27001, auditors verify that accounting records capture timestamp, source IP, user ID, event type, and outcome, with logs forwarded to centralized, write-protected repositories.

⚠️ **How CompTIA Tests This:** Exam scenario cues: 'Track user session duration and logon/logoff times', 'Measure bandwidth consumption for departmental chargeback', 'Audit forensic history of user activities'. Target answer: Accounting.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
User enters username and password or touches the biometric scanner	**Authentication (Proving Identity)**
System grants read-only rights to accounting folder based on group membership	**Authorization (Determining Permissions)**
Server logs show a user transferred 2 GB of data at 11:30 PM and logged off	**Accounting (Audit Logging & Utilization)**
AAA protocol operating over TCP port 49 that encrypts the entire payload	**TACACS+ (Targeted for Network Device Administration)**
AAA protocol operating over UDP that combines Authentication and Authorization	**RADIUS (Targeted for 802.1X, Corporate Wi-Fi, and VPN Access)**
Physical switch port remains blocked until client endpoint authenticates successfully	**IEEE 802.1X (Port-Based Network Access Control)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A financial services company requires that any employee plugging an Ethernet cable into a wall jack must authenticate before being granted access to the corporate LAN. The security architect proposes implementing port-based network access control so that switches keep ports in an unauthorized state until the user is validated by a centralized server. Which combination of technologies best meets this requirement?

A) IEEE 802.1X with a RADIUS server

B) MAC address filtering on each switch port

C) 802.1Q VLAN trunking with static port assignments

D) WPA2-Personal with a pre-shared key

QUESTION 2 · EXAM SCENARIO

An employee successfully enters valid credentials and is logged into the company's HR application. However, when the employee attempts to open a payroll report, the system displays 'Access Denied.' Which AAA component is responsible for denying the request to view the payroll report?

A) Authentication

B) Authorization

C) Accounting

D) Identification

QUESTION 3 · EXAM SCENARIO

A network operations team at a telecom provider needs to control administrative access to hundreds of Cisco routers and switches. The security lead wants each administrator to log in with their own credentials, receive their own privilege level (e.g., level 1 read-only, level 15 full admin), and have every command logged. The protocol must use TCP for reliable delivery. Which AAA protocol is the best fit?

A) RADIUS

B) TACACS+

C) LDAP

D) Kerberos

QUESTION 4 · EXAM SCENARIO

During a SOC 2 audit, the compliance team must produce evidence showing exactly who connected to the corporate VPN, the timestamps of each session, the duration of each session, and the volume of data transferred per user. Which AAA component provides this audit trail?

A) Authentication

B) Authorization

C) Accounting

D) Identification

QUESTION 5 · EXAM SCENARIO

A university wants any device that plugs into a campus Ethernet jack to be inspected before gaining access to internal systems. Faculty and staff devices that meet security requirements (managed by the university, current patches, EDR installed) should join the faculty VLAN. Student devices that fail checks should be sent to a restricted remediation VLAN where they can download updates before being re-evaluated. Which technology should the university deploy?

A) VLAN hopping prevention with private VLANs

B) Network Access Control (NAC) with posture assessment

C) Port security with sticky MAC addresses

D) MAC address filtering on access switches

QUESTION 6 · EXAM SCENARIO

During an 802.1X transaction, the user laptop runs a client called supplicant.exe, the Ethernet switch receives EAP messages and forwards them upstream, and a Windows Server running Network Policy Service (NPS) ultimately makes the allow/deny decision. What role does the Ethernet switch play in this conversation?

A) Supplicant

B) Authenticator

C) RADIUS server

D) Certificate authority

QUESTION 7 · EXAM SCENARIO

A retail chain wants authenticated employees to be placed on VLAN 10 (point-of-sale traffic), authenticated contractors to be placed on VLAN 20 (limited access), and unauthenticated or non-compliant devices to land on VLAN 99 (guest/internet only). After successful RADIUS authentication, which mechanism tells the switch which VLAN to assign to the user's port?

A) The RADIUS shared secret

B) RADIUS authorization attributes such as Tunnel-Type, Tunnel-Medium-Type, and Tunnel-Private-Group-ID

C) The RADIUS UDP accounting port 1813

D) The MAC address of the authenticating client

QUESTION 8 · EXAM SCENARIO

A security administrator configures a new VPN gateway that requires each remote user to enter their corporate password AND a six-digit code that rotates every 30 seconds on a hardware token issued by the company. Which authentication factor categories are being used?

A) Two knowledge factors (something you know)

B) Two possession factors (something you have)

C) Something you know combined with something you have

D) Something you are combined with something you know

QUESTION 9 · EXAM SCENARIO

A security architect is comparing protocols for centralizing AAA services and notices that one candidate protocol only encrypts the password field in the Access-Request packet, while the other candidate encrypts the entire payload of every packet including usernames and authorization responses. Which protocol encrypts the entire payload?

A) RADIUS, because it uses UDP for speed

B) TACACS+, which encrypts the entire body of every packet

C) Kerberos, which encrypts all traffic using AES

D) LDAP with StartTLS, which encrypts the directory session

QUESTION 10 · EXAM SCENARIO

When a BYOD laptop connects to the corporate wireless network, the NAC agent inspects the operating system build number, verifies that the antivirus engine is running and not more than three days out of date, and confirms that the device is joined to the corporate domain. If any check fails, the device is placed on a remediation VLAN with access only to the patch and AV update servers. What is the name of this inspection process?

A) Port security enforcement

B) Posture assessment (endpoint health check)

C) MAC authentication fallback

D) VLAN hopping

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — IEEE 802.1X with a RADIUS server

IEEE 802.1X is the standard for port-based Network Access Control. The switch acts as the authenticator, the supplicant is the client software on the endpoint, and a RADIUS server performs the actual authentication decision before the port transitions to the authorized state. MAC filtering, VLAN tagging, and WPA2-PSK do not provide this dynamic, user-based port-level authentication.

Question 2: Option B — Authorization

Authorization determines what an already-authenticated identity is permitted to do. The credentials verified the user's identity (Authentication), while the access control list or permission set blocked the specific resource, which is an Authorization decision. Accounting logs what the user did afterward; Identification is simply presenting an identity claim (e.g., a username).

Question 3: Option B — TACACS+

TACACS+ is purpose-built for device administration. It separates Authentication, Authorization, and Accounting into independent functions (AAA architecture), supports per-user or per-group privilege levels, encrypts the entire payload (not just the password), and uses TCP port 49 for reliable transport. LDAP and Kerberos are directory/authentication protocols, not AAA frameworks for network device administration.

Question 4: Option C — Accounting

Accounting captures and records what authenticated and authorized users actually did: session start/stop times, duration, bytes transferred, commands executed, and resources accessed. This trail is what auditors review. Authentication verifies identity, Authorization grants permissions, and Identification is the initial presentation of a username (not a verified identity).

Question 5: Option B — Network Access Control (NAC) with posture assessment

Network Access Control (NAC) evaluates the security posture of connecting endpoints (OS version, AV/EDR status, patches, certificates) and assigns them to VLANs based on the result of the posture assessment. Remediation VLANs are a classic NAC pattern. Port security only limits which MAC addresses may use a port; it does not inspect endpoint health. MAC filtering and private VLANs do not perform health checks.

Question 6: Option B — Authenticator

In 802.1X, the three roles are: Supplicant (the client software on the endpoint), Authenticator (the switch or AP controlling the port), and Authentication Server (the RADIUS/NPS server making the policy decision). The switch in this scenario is the Authenticator — it enforces the authorized/unauthorized state of the port based on what the RADIUS server decides.

Question 7: Option B — RADIUS authorization attributes such as Tunnel-Type, Tunnel-Medium-Type, and Tunnel-Private-Group-ID

RADIUS authorization attributes — particularly the Tunnel-Type, Tunnel-Medium-Type, and Tunnel-Private-Group-ID attributes (RFC 2868) — instruct the switch to place the authenticating endpoint into a specific VLAN. This is how dynamic VLAN assignment works. The shared secret authenticates the RADIUS conversation itself, port 1813 is for accounting, and the MAC address is only used for identification, not VLAN assignment.

Question 8: Option C — Something you know combined with something you have

The password is 'something you know' (a knowledge factor) and the rotating hardware token is 'something you have' (a possession factor). Combining them creates multi-factor authentication. Biometric factors ('something you are') are not present. Two of the same category would not be true multi-factor authentication.

Question 9: Option B — TACACS+, which encrypts the entire body of every packet

TACACS+ encrypts the entire body (payload) of every packet between the AAA client and server, including username, authorization attributes, and accounting records. RADIUS only encrypts the password field in the Access-Request packet, leaving usernames and other attributes readable to anyone who captures the traffic. This is one of the main reasons TACACS+ is preferred for administrative access to network devices.

Question 10: Option B — Posture assessment (endpoint health check)

Posture assessment (also called health checking or endpoint compliance) is the NAC process that inspects an endpoint's security state — OS version, AV status, patch level, domain membership, certificates — and decides whether

to grant full access, deny access, or redirect to a remediation network. Port security is a Layer 2 feature limiting MAC addresses; MAC authentication is a separate 802.1X fallback method; VLAN hopping is an attack, not a NAC function.